The Offensive Security Roadmap

From Zero to Your First Pentest — Without Drowning in Tutorials

A practitioner's 90-day plan, the tools that actually matter, and the 5 mistakes that keep people stuck in "tutorial hell."

By Belizaire Bassette II — Founder, Forethreat Security · Penetration Tester · BSCP · eJPT (OSCP in progress) *From intern to working penetration tester and Burp Suite Certified Practitioner. Every tool and lab in this roadmap is one I've used myself.*

> **Why I wrote this.** Everything you need to break into offensive security is free and online. So why do 9 out of 10 people stall out? It's not the information. It's the **order**, the **map**, and having someone **catch your mistakes**. This is the map. It's the exact path I walked. Follow it and you'll go further than 90% of people — alone. When you want to compress years into months, you'll know where I am.

The brutal truth about "tutorial hell"

You've watched the videos. You've done the walkthroughs. You can follow along when someone else drives — but sit you in front of a fresh box and… nothing.

That's not a you problem. **Tutorials teach you to follow steps. Attackers don't follow steps — they think.** The gap between "I finished the lab" and "I found the bug myself" is where almost everyone quits.

This roadmap closes that gap in three phases. Do the work in order. Don't skip.

Phase 1 — Foundations (Weeks 1–4)

You cannot attack what you don't understand. Resist the urge to jump straight to "hacking."

What to learn - **Networking:** TCP/IP, ports, DNS, HTTP/S, subnetting basics. Know what a packet *is*. - **Linux:** live on the command line. File system, permissions, bash, `grep` / `find` / `awk`, SSH. - **Web fundamentals:** how requests/responses work, cookies, sessions, status codes,

the browser dev tools Network tab. - **One scripting language — Python.** Enough to automate: loops, requests, file I/O.

Do this, not that - Build a home lab: a VM host, Kali, one deliberately-vulnerable target. - Break something you built. Understand *why* it broke. - Don't buy 5 courses. Don't memorize tool flags. Don't touch Metasploit yet.

Free/cheap tools & resources: VirtualBox/VMware · Kali Linux · TryHackMe (~$14/mo — the best on-ramp) · OverTheWire (Bandit) for Linux muscle memory.

Milestone: you can navigate Linux without Googling every command, and you can explain how a login form talks to a server.

Phase 2 — Core Offensive Skills (Weeks 5–9)

Now you attack — with a methodology, not a tool dump.

The methodology that matters (memorize this loop — it's what separates operators from button-pushers):

> **Enumerate → Identify → Exploit → Pivot → Document.** Attackers *chain* small weaknesses into a breach. One low-severity bug is boring; three chained together is a headline.

Web (start here — highest ROI for beginners): learn the OWASP Top 10 by *doing*. The bugs that pay my bills: **IDOR/BOLA, XSS (stored & reflected), file upload, CSRF, mass assignment.** Learn Burp Suite (Community is free) — proxy, Repeater, Intruder.

Network: enumeration with Nmap, service identification, common misconfigurations. Understand *why* a port matters, not just that it's open.

Practice platforms: TryHackMe paths → **HackTheBox** (~$28/mo) → PortSwigger Web Security Academy (**free and excellent**).

Do this, not that - Keep an attack journal. Every box: what you tried, what worked, what you missed. - Try *before* you look at the walkthrough. Struggle is the reps. - Don't copy-paste payloads you can't explain. Don't chase every tool on Twitter.

Milestone: you found a vulnerability *on your own*, wrote a working proof-of-concept, and can explain the business impact in one sentence.

Phase 3 — Proof & Positioning (Weeks 10–13)

Skills nobody can see don't get you hired or paid. Turn practice into evidence.

- **Write reports.** For every box, write a mini pentest report: finding, severity (learn CVSS), reproduction steps, evidence, remediation. *This is the actual job.* Most candidates can hack a little and document nothing — be the opposite.
- **Build a public portfolio.** A GitHub/blog with sanitized writeups. Recruiters and clients read these.
- **Pick a certification target: eJPT** (great first cert — proves you can do the loop) → then **OSCP** (the market standard) or **BSCP** (web specialist).
- **Get on the map:** answer real questions on r/netsecstudent and r/oscp. Being genuinely helpful *is* marketing.

Milestone: a portfolio with 3+ clean writeups, one certification booked or earned, and a report you'd be proud to hand a client.

The 5 mistakes that keep people stuck

1. **Tutorial hell** — consuming instead of producing. If you're not stuck and struggling, you're not learning.
2. **Tool obsession** — collecting tools instead of understanding attacks. Tools change; methodology doesn't.
3. **Skipping fundamentals** — trying to exploit what you don't understand. It always catches up with you.
4. **No documentation** — you can hack but can't prove or communicate it. Reporting *is* the profession.
5. **Learning alone with no feedback loop** — the silent killer. You repeat the same blind spots for months because no one tells you what you're missing.

The 90-day plan at a glance

Weeks	Focus	You can…
1–4	Foundations	Live in Linux; explain web requests; run a home lab
5–9	Core offense	Find & exploit OWASP Top 10 bugs; use Burp & Nmap with intent
10–13	Proof	Write real reports; publish writeups; book a cert

Realistic honesty: expect **6–12 months and 400–800 hours** to become genuinely job-ready. This roadmap gets you moving in the right direction from day one — which is more than most people ever manage.

The one thing this PDF can't give you

A roadmap shows you the mountain. It doesn't hand you a rope.

The single biggest accelerator isn't another course — it's a **feedback loop**: someone already inside who looks at what you did, tells you exactly what you missed, and cuts years off your timeline. That's the difference between "I did the lab" and "I found it myself." It's the one mistake on the list you literally cannot fix alone.

That's what I do. I went from intern to working penetration tester, earned the BSCP (PortSwigger's hands-on web exploitation exam), and I now mentor people through this exact path — 1:1, with real labs, real attack paths, and real feedback on your work.

> **Ready to compress years into months?** **Book a free 20-minute intro call** — I'll map your personal roadmap live, whether or not you ever buy: **forethreatsec.com/start.html**
> Or DM me **MENTOR** on Instagram @forethreatsec.
>
> *Think like an attacker. I'll show you how.*

© Forethreat Security LLC · forethreatsec.com · This roadmap is free to share. Securing the digital world by understanding threats before they strike.